

海淘优选（杭州）科技有限公司 PIIPIA 报告草案

基础信息

- 企业名称：海淘优选（杭州）科技有限公司
- 合规路径：scc_filing
- 境外接收方：SeaCommerce Pte. Ltd.（新加坡）
- 出境目的：个性化营销与市场分析
- 风险等级：HIGH

处理者与出境活动基础信息

第一章 处理者与出境活动基础信息

（一）数据处理者基本情况

- 1 个人信息处理者名称为海淘优选（杭州）科技有限公司。
- 2 根据提供的信息，本次出境活动涉及的个人信息规模为500,000人，其中包含敏感个人信息10,000人。处理者已达到《个人信息保护法》规定的需指定个人信息保护负责人的数量要求 [1]。
- 3 处理者作为个人信息处理活动的责任主体，应遵循合法、正当、必要和诚信原则，并对其个人信息处理活动负责，采取必要措施保障所处理的个人信息的安全 [2][3]。

（二）出境业务场景描述

- 1 出境目的与方式：本次数据出境的目的为“个性化营销与市场分析”。具体业务场景为，将中国大陆约50万名高价值会员的偏好标签、浏览记录（哈希设备ID）和订单摘要，通过加密API从杭州的数据库定期传输至位于新加坡的境外接收方，由接收方完成会员分析，以提供个性化的商品推荐和营销活动。
- 2 涉及的个人信息：出境涉及的个人信息种类包括会员等级（MemberTier）、哈希设备ID（HashedDeviceID）、产品类别偏好（ProductCategoryPreference）、最近购买金额（LastPurchaseAmount）、月均浏览次数（AvgMonthlyBrowseCount）等。根据《个人信息保护法》，个人信息是以电子方式记录的与已识别或者可识别的自然人有关的各种信息，其处理包括传输、提供等 [4]。其中，“产品类别偏好”字段包含如“母婴用品”、“医疗保健品”等可能推断个人特定身份或健康状态的信息，存在被认定为敏感个人信息的风险 [5]。
- 3 处理的法律基础：企业当前主张的处理法律基础为取得个人的“单独同意”。同时，企业亦提出“合同履行必要性”的主张，即认为提供个性化服务是履行与用户之间服务合同所必需。根据《个人信息保护法》，向境外提供个人信息需取得个人的单独同意 [6]。若主张合同履行之必要性，需进行充分论证。

（三）适用合规路径

- 1 路径判断：根据国家网信部门制定的《个人信息出境标准合同办法》，本次数据出境活动适用于“订立个人信息出境标准合同”的合规路径（简称“标准合同路径”）。企业选择的合规路径为“SCC备案”，与此相符。
- 2 路径适用前提：采用标准合同路径出境，要求个人信息处理者与境外接收方签订国家网信部门制定的标准合同，并依法履行备案手续。此路径适用于非关键信息基础设施运营者，且出境个人信息未达到国家网信部门规定数量（指重要数据）的情形 [7]。根据现有信息，未提供本次出境数据被识别为“重要数据”的依据。
- 3 与认证路径的关系：本次评估未涉及通过专业机构进行个人信息保护认证的路径（“认证路径”）。标准合同路径是本次出境活动拟采用的唯一合规路径。

个人信息出境处理活动说明

第二章 个人信息出境处理活动说明

(1) 个人信息类型和字段清单

根据提供的附件材料，本次出境的个人信息涉及约50万名高价值会员，其中包含约1万名敏感个人信息主体。出境的具体个人信息字段如下：

1 一般个人信息：

* Member_Tier：会员等级。

* HashedDeviceID：经哈希处理的设备标识符。根据附件，企业主张其为“去标识化设备ID”并选择“非个人信息”，但未提供哈希算法、碰撞风险及重新识别风险的评估报告，其个人信息属性及匿名化有效性待确认。

。

* LastPurchaseAmount：最近一次购买金额。

* AvgMonthlyBrowse_Count：月均浏览次数。

1 敏感个人信息：

* ProductCategoryPreference：产品品类偏好。附件指出该字段包含“母婴用品”、“医疗保健品”等可能推断个人特定身份、健康状态等敏感状况的标签。根据《中华人民共和国个人信息保护法》第28条，此类信息一旦泄露或非法使用，容易导致自然人的人格尊严或人身、财产安全受到危害，应被认定为敏感个人信息[5]。企业当前将其标注为“非敏感信息”的分类不准确，需重新评估。

(2) 处理目的和法律依据

1 处理目的：向境外接收方提供个人信息，用于“个性化营销与市场分析”，具体包括为高价值会员提供个性化的商品推荐和营销活动，以提升用户体验和复购率。

2 法律依据：

* 企业当前主张的法律基础为“基于个人同意”以及“为履行与用户之间的服务合同（提供个性化服务）所必需”[8]。

单独同意*：根据《个保法》第39条，向境外提供个人信息，应向个人告知境外接收方的详细信息，并取得个人的单独同意[6]。附件显示，企业已提供单独同意界面截图，但尚未能提供覆盖全部50万目标用户的批量同意记录清单，同意有效性存疑。此外，当前隐私政策仅概括提及“关联方”，未明确列出境外接收方“SeaCommerce Pte. Ltd.”的名称及联系方式，告知不充分[9]。

合同履行必要性*：企业主张“提供个性化服务”为履行合同所必需。此论证较为宽泛，将“个性化营销”等同于合同核心服务内容的必要性有待复核，可能不符合最小必要原则[2]。

敏感个人信息处理*：若ProductCategoryPreference被最终认定为敏感个人信息，则必须依据《个保法》第29条，就该敏感个人信息的出境处理取得个人的单独同意[10]。

(3) 数据流转图说明

根据附件材料，数据流转路径如下：

- 1 数据源：个人信息存储于海淘优选（杭州）科技有限公司位于杭州的阿里云RDS数据库中。
- 2 传输过程：数据通过加密API方式，定期从境内数据库同步。
- 3 出境与接收：数据跨境传输至位于新加坡的AWS云服务环境。
- 4 境外处理：境外接收方SeaCommerce Pte. Ltd. 将接收的数据存入其Amazon Redshift数据仓库

境外接收方信息与保护能力

(1) 接收方基本信息

根据提供的材料，本次个人信息出境的境外接收方为 SeaCommerce Pte.

Ltd.，是一家注册于新加坡的公司，系个人信息处理者海淘优选（杭州）科技有限公司的全资子公司 [11]。接收方将基于委托处理关系，为处理者提供“个性化营销与市场分析”服务，处理约50万名会员的个人信息，其中包括可能涉及敏感个人信息的偏好标签 [12]。目前，标准合同草案中已载明双方主体及出境目的，但隐私政策中关于“关联方”的列举未明确列出该接收方的具体名称和所在地，告知不充分 [9][6]。

(2) 目的地国数据保护立法水平评估

接收方所在地新加坡已制定《个人数据保护法》（PDPA），建立了个人信息保护的基本法律框架。PDPA确立了同意、目的限定、访问与更正等核心原则，并设有专职的数据保护监管机构（个人数据保护委员会）。这表明新加坡具备一定水平的数据保护立法。然而，评估不能仅停留在立法存在层面。根据《个人信息保护法》第三十八条的要求，需持续关注接收方所在国家或地区的法律环境和监管实践是否能够提供与中国《个人信息保护法》实质相当的保护水平，或至少不损害所传输个人信息的安全与中国法律赋予的个人权益。当前材料仅声明接收方“遵守新加坡PDPA”，但未提供任何关于新加坡法律与中国法在保护水平上的对比分析，也未提供针对新加坡法律或监管政策未来可能发生不利变化时的应对机制约定。此部分评估存在信息缺口，构成风险。【待核验：缺少法规依据】

(3) 接收方已建立的技术和管理保护措施

根据现有材料，对接收方保护措施的评估如下：

- 1 管理措施：接收方声明其遵守新加坡PDPA，但未提供任何可验证的第三方审计报告、合规认证证书或详细的内部政策文本（如全球隐私政策）以证明其已建立完善的管理制度 [13]。标准合同草案中亦缺少关于接收方需定期提交独立安全审计报告和整改证明的明确约定，导致处理者难以进行有效监督 [12]。
- 2 技术措施：数据传输过程采用了加密API，表明在传输环节采取了加密技术措施。然而，对于出境数据中的“哈希设备ID”，未提供所采用哈希算法的具体信息、强度及防碰撞风险分析报告，无法有效评估其去标识化效果及重标识化风险 [4]。
- 3 响应与保障措施：标准合同草案在数据主体权利行使的跨境协作机制、个人信息安全事件的通知与响应、以及合同终止后数据的删除或返还安排等方面存在条款缺失或约定不明的情况 [14][15]。

综上，境外接收方 SeaCommerce Pte. Ltd. 虽位于有数据保护立法的法域，但其实际建立并可供验证的技术和管理保护措施证明不足，合同约束机制存在关键缺口，无法充分证明其具备与本次出境活动高风险等级相匹配的保护能力 [3][16]。

个人信息主体权益影响评估

第四章 个人信息主体权益影响评估

(1) 对知情同意权的影响

根据现有材料，本次个人信息出境活动对个人信息主体的知情同意权构成显著影响，主要体现在告知不充分与同意有效性存疑两个方面。

首先，在告知义务的履行上存在缺陷。企业当前的隐私政策仅概括性提及向“关联方”提供信息，未按照法律要求明确告知境外接收方“SeaCommerce Pte.

Ltd.”的具体名称、联系方式、处理目的、处理方式及个人信息种类

[9][6]。这种不明确的告知，使得个人无法在充分知情的前提下作出判断，违反了公开、透明原则 [17]。

其次，在获取同意方面存在风险。企业主张处理的法律基础为“单独同意”，但仅提供了界面截图，未能提供覆盖全部50万目标会员的批量同意记录以证明同意的有效性、自愿性和明确性 [18]。此外，对于可能涉及敏感个人信息的“母婴用品”、“医疗保健品”等偏好标签，企业当前将其归类为非敏感信息，若经重新评估确认为敏感个人信息，则必须依法重新获取单独同意，而现有材料未显示已完成此项工作 [5][10]。

(2) 对各项权利行使的影响

本次出境活动对个人行使查阅、复制、更正、删除等权利构成了实质性障碍，主要源于跨境场景下的机制缺失。

根据《个人信息保护法》，个人信息处理者应当建立便捷的个人行使权利的申请受理和处理机制 [14]。然而，现有标准合同草案及支持材料中，“数据主体权利请求渠道、境外接收方响应时限和跨境投诉转交机制尚待补充”。这意味着，当个人信息主体向海淘优选公司提出行权请求，特别是涉及要求境外接收方删除或更正信息时，缺乏明确的合同条款和操作流程来保障该请求能被有效传达至境外接收方（SeaCommerce Pte. Ltd.）并得到及时执行 [12]。

此外，出境目的涉及“个性化营销与市场分析”，属于利用个人信息进行自动化决策。根据法律，企业需保证决策的透明与公平，并提供便捷的拒绝方式 [19][20]。在数据出境后，个人如何向境外接收方行使拒绝自动化决策的权利，现有机制亦不明确，增加了个人权益受损的风险。

(3) 风险等级评定及依据

风险等级：高

评定依据：

- 1 核心法定程序存在重大缺陷：告知不充分与同意有效性证明不足，直接动摇了本次出境活动的合法性基础 [2][8]。在未进行有效告知并获得有效同意的情况下处理并出境个人信息，尤其是可能涉及敏感个人信息，对个人权益的影响是根本性和高风险的。
- 2 个人行权机制严重缺失：个人在数据出境后行使权利的渠道和保障机制尚未建立，导致其查阅、更正、删除及拒绝自动化决策等核心权利可能无法实现，权益救济途径受阻 {{CIT-CN-CNLA003-ART50

技术与组织措施有效性评估

第五章 技术与组织措施有效性评估

(1) 技术安全措施评估

根据现有材料，海淘优选（杭州）科技有限公司（以下简称“处理者”）为本次个人信息出境活动所采取的技术安全措施存在显著不足，无法有效保障数据安全，具体评估如下：

- 1 数据传输与存储加密措施不明确：材料指出数据通过加密API从杭州阿里云同步至新加坡AWS，但未提供加密算法的具体类型、强度以及密钥管理机制，无法评估其能否有效防止传输和存储过程中的数据泄露、篡改或非法访问 [13]。
- 2 去标识化技术有效性存疑：出境数据中包含“HashedDeviceID”字段，处理者主张其为去标识化信息。然而，材料未提供所采用的哈希算法、抗碰撞分析报告以及重新识别风险评估。在缺乏这些关键信息的情况下，无法认定该技术措施能有效防止个人信息被重新识别，该字段仍应被视为个人信息 [4]。
- 3 敏感信息识别与保护措施缺失：出境数据中的“ProductCategoryPreference”字段包含“母婴用品”、“医疗保健品”等可能推断个人健康等敏感状况的标签，但当前被错误归类为非敏感信息。这表明处理者未对个人信息实行有效的分类管理，也未针对敏感个人信息采取法律要求的严格保护技术措施 [5][13]。
- 4 自动化决策透明度与干预措施未说明：本次出境的目的是“个性化营销”，属于利用个人信息进行自动化决策。现有材料未说明处理者及境外接收方是否采取了保证决策透明度、结果公平公正的技术措施，也未提供便捷的拒绝方式或非个性化选项 [19][20]。

(2) 组织管理措施评估

处理者在组织管理措施方面存在制度陈旧、职责不清、监督缺位等问题，管理体系的有效性严重不足：

- 1 内部管理制度不健全且未更新：处理者提供的《个人信息安全管理制度》版本为2023年，未能反映《个人信息保护法》及后续配套法规的最新要求，也未针对本次特定的个人信息出境场景制定专门的操作规程，不符合动态管理要求 [13]。

- 2 个人信息保护负责人职责履行不充分：虽然处理者处理个人信息数量已达到需指定负责人的标准，但材料未展示该负责人如何对本次出境活动及保护措施进行有效监督，也未提供其参与评估、审计等相关工作的记录 [1]。
- 3 对境外接收方的监督机制缺失：根据《个人信息出境标准合同》要求，处理者需对境外接收方的处理活动进行监督。然而，现有法律文件草案中缺少要求接收方定期提交安全审计报告、证明其持续合规能力的关键条款，也未约定在接收方所在法律环境发生变化时的通知与评估机制，导致监督无法落地 [12]。
- 4 应急响应与合规审计机制未证实：材料未提供个人信息安全事件应急预案的演练记录或合规审计的计划与报告，无法证明处理者具备及时发现、处置安全事件的能力，也未履行定期进行合规审计的法定义务 [21]]{{CIT-CN-CN_

事件响应与整改计划

(1) 安全事件应急响应机制

为履行《个人信息保护法》规定的安全保护义务，海淘优选（杭州）科技有限公司（以下简称“本公司”）已依据《个人信息保护法》第五十一条、第五十七条的要求，建立个人信息安全事件应急响应预案。该机制旨在确保在发生或可能发生个人信息泄露、篡改、丢失等安全事件时，能够迅速、有效地采取补救措施，控制并消除危害，并依法履行报告与通知义务。【待核验：缺少法规依据】

应急响应流程遵循以下核心步骤：

- 1 监测与发现：通过技术监测系统与人工巡检相结合的方式，对数据处理活动进行7x24小时监控，确保及时发现异常。
- 2 初步研判与启动：一旦发现安全事件，由信息安全团队立即进行初步研判，确定事件性质、影响范围和潜在危害等级，并即刻启动应急响应程序。
- 3 遏制与补救：采取必要的技术与管理措施（如隔离系统、修复漏洞、阻断异常访问、追踪数据流向等）遏制事件发展，防止危害扩大，并尽最大可能减少损失。
- 4 评估与报告：根据《个人信息保护法》第五十七条，在事件发生后立即进行深入评估。若事件可能对个人权益造成损害，本公司将按照规定时限，向履行个人信息保护职责的部门报告，并通知受影响的个人。通知内容将包括事件概况、可能影响、已采取的补救措施以及个人可采取的减轻风险的建议。
- 5 调查与整改：成立专项调查组，查明事件根本原因，并制定并实施整改措施，防止类似事件再次发生。
- 6 记录与归档：对整个应急响应过程进行详细记录，形成事件报告并存档，作为后续审计与改进的依据。

本公司已指定个人信息保护负责人负责监督应急响应机制的执行，并确保与境外接收方SeaCommerce Pte. Ltd.建立有效的事件协同响应通道，明确双方在跨境场景下的责任与协作流程。

(2) 已识别风险的整改措施和时间表

基于本次个人信息保护影响评估（PIPIA）的发现，本公司针对识别出的高风险与中风险项，制定如下整改计划：

序号	已识别风险项	整改措施	责任部门	计划完成时间
1	告知不充分：隐私政策未明确列明境外接收方SeaCommerce Pte. Ltd.的名称、联系方式及处理目的等关键信息 [9][6]。	全面修订《隐私政策》，以显著、清晰的方式单独列明本次个人信息出境的境外接收方信息、处理目的、方式、种类及个人行使权利的方式，并重新获取用户的单独同意。	法务合规部、产品部	2025年XX月XX日前完成修订并上线；同步启动重新获取同意流程。

序号	已识别风险项	整改措施	责任部门	计划完成时间
2	同意记录不完整：未能提供覆盖全部50万目标用户的批量同意日志，同意有效性存疑 [18][11]。	1. 梳理并修复同意管理系统的日志记录功能，确保未来所有单独同意操作均有完整、不可篡改的日志。 2. 对历史同意记录进行审计与补全，确保能够证明本次出境活动已获得有效单独同意。	技术部、数据合规部	2025年XX月XX日前完成系统修复与历史审计。
3	敏感信息识别与保护不足：“ProductCategoryPreference”			

PIPIA 结论与备案建议

第七章 PIPIA结论与备案建议

(1) 整体PIPIA评估结论

基于本次评估，海淘优选（杭州）科技有限公司拟向境外接收方SeaCommerce Pte. Ltd.（新加坡）提供个人信息用于“个性化营销与市场分析”的活动，总体风险等级为高风险，在完成下述关键整改前，无法得出风险可控的结论。

主要高风险项包括：

- 1 合法性基础存在重大缺陷：当前主张的法定基础为“单独同意”，但所附证据（隐私政策及同意记录）未能充分满足法律要求。隐私政策未明确告知境外接收方的具体名称与联系方式 [9]，且未能提供覆盖全部50万目标个人的有效单独同意证明 [6]。同时，“合同履行必要性”的主张依据不足，有待复核。
- 2 敏感个人信息识别与保护不足：出境信息中的“ProductCategoryPreference”（如母婴用品、医疗保健品）可能用于推断个人健康等敏感状况，但企业当前将其归类为非敏感信息，存在分类错误，未履行处理敏感个人信息所需的严格保护义务及获取单独同意的要求 [5][10]。
- 3 境外接收方安全保障能力未得到有效验证：境外接收方仅声明遵守新加坡法律，但未提供任何第三方审计报告、认证证书或其他客观材料证明其具备与中国《个人信息保护法》要求相称的安全保护能力 [22]。
- 4 标准合同草案存在关键条款缺失：现有合同草案缺少对境外法律环境变化的应对机制、接收方定期审计监督要求、合同终止后数据处置安排等核心条款，无法有效约束境外接收方并保障个人信息权益 [12]。

(2) 适用合规路径建议

根据《个人信息保护法》第三十八条规定，向境外提供个人信息需满足法定条件之一 [22]。结合本企业非关键信息基础设施运营者、出境个人信息规模（50万人）及包含敏感个人信息（1万人）的实际情况，并依据企业选择的路径，建议如下：

适用路径：订立个人信息出境标准合同

鉴于企业已选择标准合同路径（scc_filing），且当前出境活动不满足安全评估或认证路径的优先适用条件（未提供证据表明涉及重要数据或达到更大规模），通过订立并备案标准合同是可行的合规路径。但必须强调，此路径的适用前提是彻底完成上述高风险项的整改，并签署一份完全符合国家网信部门制定范本要求的《个人信息出境标准合同》。

(3) 备案材料准备指引

为完成标准合同备案，企业必须在提交前确保以下核心材料完备、合规：【待核验：缺少法规依据】

1 修订并签署完备的《个人信息出境标准合同》：

* 必须依据国家网信部门发布的正式范本，补全现有草案所有缺失条款，特别是境外法律政策变化应对、接收方审计监督、合同终止后数据删除与返还等。

* 合同中对个人信息处理目的、范围、方式的约定必须与本次评估报告及对个人的告知内容完全一致。

【待核验：缺少法规依据】

1 完善个人信息处理规则与同意管理证据：

修订隐私政策*：明确、具体地告知个人境外接收方（SeaCommerce Pte.

Ltd.）的名称、联系方式、处理目的、个人信息种类及个人行使权利的方式等

附件摘要

- case_03_seacommerce_scc_draft.md: # 个人信息出境标准合同草案（脱敏测试夹具）> 文件性质：本文件根据“认证/标准合同路径”测试案例一派生，仅用于本地自动化验收；不是案例原文附件，不是正式签署文本，也不能作为真实备案材料。## 一、合同主体与出境场景 - 个人信息处理者：海淘优选（杭州）科技有限公司。- 境外接收方：SeaCommerce
- “认证_标准合同路径”测试案例及预期输出.docx: “认证/标准合同路径”测试案例及预期输出
测试案例一：跨境电商平台会员营销数据出境（标准合同路径）场景背景：“海淘优选”（非CIIO）是一家面向中国消费者的跨境电商平台，计划将其中国大陆的800万注册会员中的约50万高价值会员（年消费超万元）的偏好标签、浏览历史（去标识化设备ID）和部分订单摘要（不含直接联系信息）传